AI SECURITY REFERENCE ARCHITECTURE

Enterprise & Government AI Platform

Implementation Baseline • Version 1.0 • October 2026

Architecture diagrams • Control tables • Governance • Deployment roadmap • Assurance model

Document Control

Field	Value
Document title	AI Security Reference Architecture — Enterprise & Government AI Platform
Version / status	1.0 — Reference baseline for architecture review and implementation planning
Date	October 2026
Audience	CIO, CISO, AI platform leadership, enterprise architects, data owners, risk/compliance, procurement
Scope	LLM/SLM/ML applications, RAG, vector stores, agents, APIs, model lifecycle, AI operations
Use limitation	This is a target/reference design, not evidence that any environment has already implemented or certified these controls.

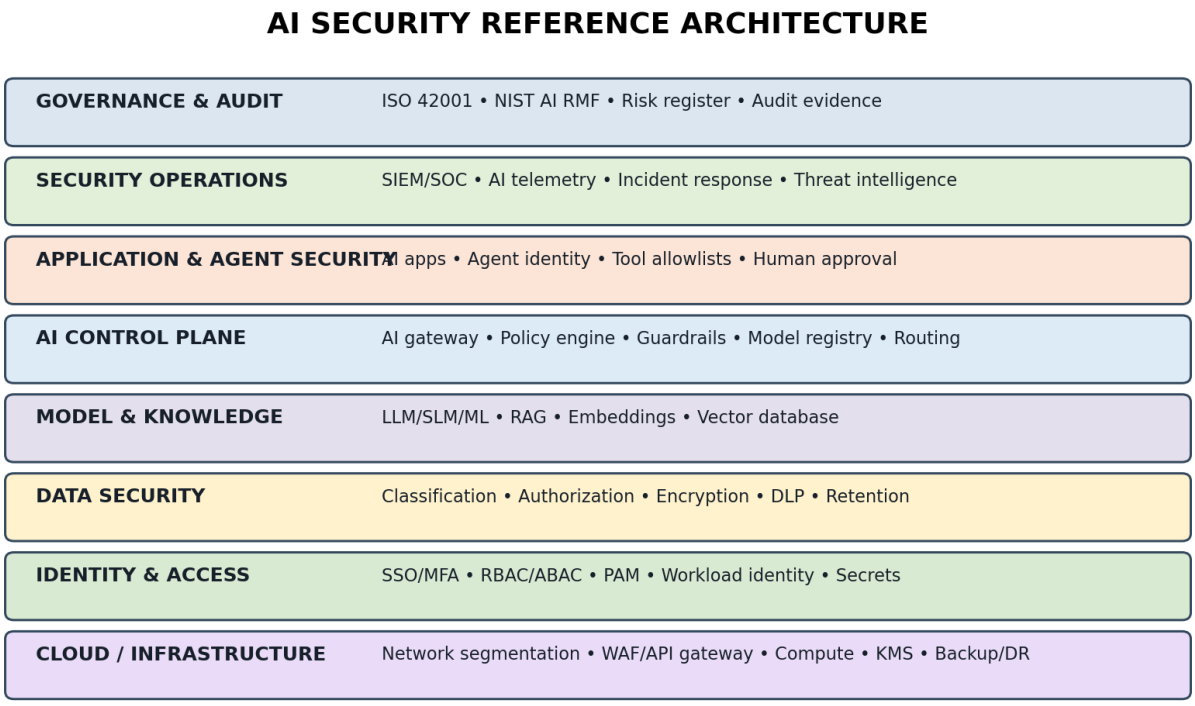
1. Executive Summary

This document defines a practical, vendor-neutral reference architecture for securing enterprise and government AI platforms. It places identity, data authorization, model governance, application guardrails, agent permissions, security monitoring, and auditability around the complete AI lifecycle. The design is intended to be instantiated against a specific cloud/on-premises environment, threat model, data classification scheme, and applicable legal/regulatory requirements.

Design principles

- Identity first: every user, workload, model endpoint, agent, and tool call has a traceable identity.
- Authorize at the source and retrieval layer: do not rely on UI controls to prevent data leakage.
- Least privilege: agents and applications receive only the minimum permissions required.
- Secure lifecycle: models, prompts, datasets, dependencies, and configurations are versioned and assessed.
- Defense in depth: no single guardrail is treated as a complete defense against prompt injection or data exfiltration.
- Evidence by design: decisions, model versions, access checks, tests, and incidents produce auditable evidence.

2. Reference Architecture Diagram



The layers are logical boundaries, not necessarily separate products. Controls should be enforced at the point closest to the asset or action, with centralized policy and evidence collection where practical.

3. Architecture Planes and Responsibilities

Plane / layer	Key components	Security outcomes	Minimum evidence
Governance & audit	AI policy, risk register, model registry, approvals, audit service	Ownership, risk acceptance, traceability	Approved policies, risk assessments, review minutes
Security operations	SIEM/SOC, AI telemetry, incident playbooks, threat intel	Detect, investigate, contain AI-specific threats	Alert rules, runbooks, incident records
Application & agents	Apps, agent runtime, tool broker, approval workflow	Constrain tool use and high-impact actions	Tool allowlists, permissions, approval logs
AI control plane	AI gateway, policy engine, guardrails, routing	Central policy enforcement and model access	Gateway policies, config versions, test results
Models & knowledge	LLM/SLM/ML, embedding service, vector DB, RAG	Approved model use and authorized retrieval	Model cards, evaluation, retrieval ACL tests
Data security	Classification, encryption, DLP, masking, retention	Protect data through ingestion, inference and output	Classification records, key config, DLP results
Identity & access	SSO/MFA, RBAC/ABAC, PAM, workload identity, vault	Strong authentication and least privilege	Access reviews, IAM policies, secrets rotation
Infrastructure	Network segmentation, WAF, API gateway, compute, KMS, backup	Reduce attack surface and support recovery	Network rules, vulnerability scans, DR test

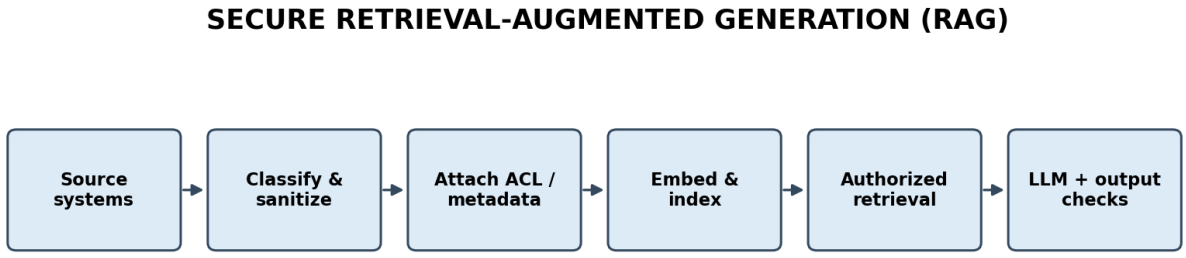
4. Trust Boundaries and Request Flow

A production request should pass through authenticated ingress, policy enforcement, application orchestration, authorized data/model access, output controls, and audit logging.

Step	Control point	Required decision / action
1	Ingress / WAF / API gateway	Authenticate caller, validate request shape,

		apply quotas and abuse controls.
2	Identity and policy	Resolve user/service identity; evaluate role, attributes, tenant, purpose and data entitlement.
3	AI security gateway	Apply prompt/input inspection, content policy, data-loss checks, token/cost limits and routing rules.
4	Orchestration / agent runtime	Enforce workflow permissions, approved tools, scoped credentials, timeouts and action budgets.
5	RAG / data access	Filter by source-system permissions and document ACLs before returning chunks to the model.
6	Model endpoint	Use approved model/version; isolate tenants; protect credentials; record model invocation metadata.
7	Output / action gate	Validate output, scan for sensitive data, apply policy; require human approval for high-impact actions.
8	Audit / SOC	Record trace ID, identity, policy decisions, model version, tool actions and outcome with privacy-aware logging.

5. Secure RAG Reference Flow



RAG controls

Control	Implementation requirement	Verification test
Source authorization	Inherit source ACLs and identity context; prevent broad service accounts from bypassing permissions.	User A cannot retrieve documents available only to User B.
Ingestion hygiene	Scan files for malware, prompt-injection content and unsupported formats; quarantine suspicious documents.	Malicious/instructional content is flagged or safely handled.
Metadata integrity	Maintain source ID, owner, classification, ACL, tenant, version and ingestion timestamp.	Metadata is complete and protected against unauthorized modification.
Embedding/index access	Restrict vector DB access to approved services; encrypt data; isolate tenants and environments.	Cross-tenant and direct-store access tests fail safely.
Retrieval traceability	Log source IDs/chunk IDs and policy outcomes without unnecessarily storing full sensitive prompts.	A sampled answer can be traced to authorized source material.
Output handling	Apply DLP/content checks and cite sources where required; do not treat model output as inherently trusted.	Seeded sensitive data is blocked or handled under approved policy.

6. Agentic AI Security

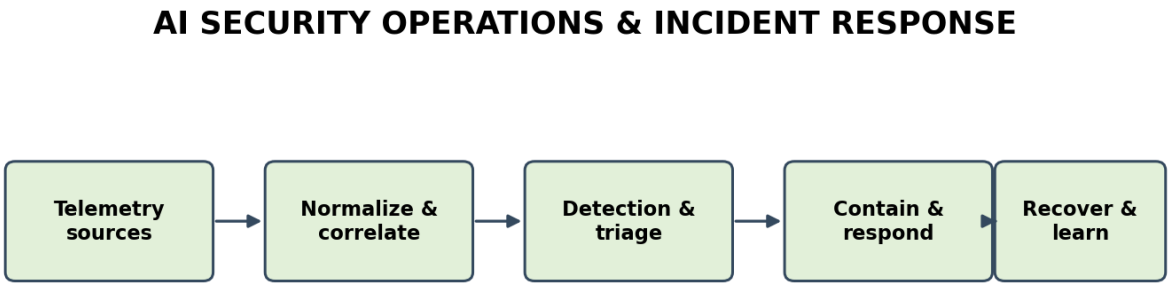
Agents must be treated as privileged automation, not as trusted users. Tool calls require independent authorization outside the model's own reasoning.

Control	Baseline requirement	Example
Agent identity	Unique identity per agent/workload; no shared human credentials.	A case-triage agent has its own workload identity.
Tool allowlist	Explicitly permit each API/tool and operation; deny by default.	Read-only case search allowed; bulk export denied.
Scoped credentials	Short-lived credentials, secret vault, rotation and environment separation.	Credential expires after task or session.
Action policy	Validate parameters, destination, transaction amount and data scope.	Payment, record modification or external communication requires approval.
Human oversight	Approval for irreversible, high-impact or externally visible actions.	Human approves citizen-record change.
Kill switch	Rapidly suspend agent, revoke tokens and disable tool access.	SOC can disable a compromised agent without taking down all AI services.
Agent audit	Record plan/task ID, tool, arguments (redacted as needed), decision, approver and result.	Incident responders reconstruct a sequence of actions.

7. Model and AI Supply-Chain Governance

Asset	Required record / control	Gate before production
Foundation model	Provider, model/version, terms, region, data-use settings, known limitations	Approved provider/model and data-handling review
Fine-tuned model	Dataset lineage, consent/rights, training pipeline, evaluation and rollback	Data approval, safety/security evaluation, model owner sign-off
Prompt/system instructions	Version, owner, change history, tests and approval	Regression and abuse-case tests
Embedding model	Version, source, compatibility and security assessment	Retrieval quality and isolation tests
Packages/containers	SBOM, image provenance, vulnerability scanning, signing where supported	No unapproved critical vulnerabilities; verified artifact source
MCP servers/plugins/tools	Owner, permissions, network destinations, version, authentication and logging	Threat model, allowlist, sandbox test and approval
Datasets/documents	Provenance, classification, access rights, retention and poisoning checks	Data owner approval and ingestion validation

8. Security Operations and Incident Response



Sources: prompts, model calls, RAG retrieval, agent/tool actions, IAM, API gateway, data platform, cloud audit

Preserve traceability while minimizing sensitive content in logs; apply retention and access controls.

Detection use case	Signals	Initial response
Prompt injection / jailbreak	Known attack patterns, repeated policy bypass attempts, anomalous instruction content	Rate-limit or block request; preserve trace; tune detection and tests.
Sensitive data exposure	DLP match, unauthorized source retrieval, sensitive output patterns	Stop response/action; contain access path; assess exposure and notification duties.
Agent misuse	Unexpected tool, privilege escalation, unusual action volume or destination	Suspend agent/tool token; require manual review; inspect execution trace.
RAG authorization failure	Cross-tenant retrieval, ACL mismatch, unauthorized chunk returned	Disable affected retrieval path; revoke access; re-index or correct ACL mapping.
Model/supply-chain compromise	Unexpected model hash/version, package alerts, provider incident	Quarantine deployment; revert to approved version; investigate lineage.
Resource abuse	Token spike, cost anomaly, rate-limit exhaustion, repeated requests	Throttle/deny, isolate abusive client, review quotas and billing telemetry.

9. Control Matrix and Standards Mapping

Control domain	Primary references	Mandatory implementation evidence
AI governance & lifecycle	ISO/IEC 42001; NIST AI RMF	AI policy, inventory, owners, risk decisions, lifecycle gates
AI risk management	ISO/IEC 23894; NIST AI RMF	Use-case risk assessment, treatment plan, residual risk acceptance
Enterprise information security	ISO/IEC 27001	ISMS control mapping, access reviews, incident and continuity processes
LLM application security	OWASP Top 10 for LLM Applications; OWASP AISVS	Threat model, abuse cases, security test report, remediation record
Agentic security	OWASP Top 10 for Agentic Applications; OWASP AISVS	Tool permission matrix, approval gates, agent trace tests
Adversarial AI	MITRE ATLAS	Threat scenarios, attack simulation and mitigation evidence
Secure development	NIST SSDF	Code review, CI/CD controls, dependency scanning, release approvals
Cloud AI controls	CSA AI Controls Matrix	Control ownership, cloud configuration evidence, vendor assurance

Use the current published edition of each reference during procurement and audit. Standards and OWASP project versions evolve; the architecture should record the exact version used in each assessment.

10. Implementation Roadmap

Phase	Indicative timeline	Work packages	Exit criteria
1. Establish baseline	0–90 days	Governance, inventory, risk tiers, IAM, data classification, architecture decisions	All production AI assets registered; owners and risk ratings assigned; critical access paths defined.
2. Enforce core controls	Months 3–6	AI gateway, DLP, RAG ACL enforcement, secrets, logging, supply-chain scanning	Security tests demonstrate access enforcement; audit events reach SOC; high-risk gaps have owners.
3. Advanced assurance	Months 6–9	AI red team, agent controls, ATLAS scenarios, automated evaluations, incident drills	Critical use cases pass independent tests; incident playbooks exercised.
4. Independent assurance	Months 9–12	Control effectiveness, audit evidence, standards alignment, DR and continuous improvement	Exceptions approved; evidence pack complete; corrective actions tracked.

11. Governance and Accountability

Role	Accountability
AI Governance Council	Approve policy, risk appetite, high-impact use cases and material exceptions.
CIO / Platform owner	Own platform design, availability, capacity and delivery roadmap.
CISO / Security architecture	Own security baseline, threat model, control validation and security exceptions.
Data owner / privacy lead	Approve data purpose, classification, access, retention and privacy controls.
AI/model owner	Own model evaluation, limitations, release approval, monitoring and retirement.
Application/agent owner	Own tool permissions, application controls, user experience and operational risk.
SOC / incident response	Monitor events, investigate incidents, contain threats and preserve evidence.
Internal audit / independent assessor	Independently test design and operating effectiveness; verify evidence.

12. Minimum Acceptance Checklist

☐ AI use case, business owner, technical owner and risk tier are recorded.

☐ Model, prompt, dataset, embedding model and tool versions are traceable.

☐ User and workload identities are authenticated; least privilege is enforced.

☐ RAG retrieval enforces document-level authorization before content reaches the model.

☐ Agent tools are allowlisted; high-impact actions have approval and rollback paths.

☐ Sensitive data is protected in prompts, retrieval, outputs, logs and backups.

☐ AI-specific abuse cases and adversarial tests are completed and documented.

☐ Telemetry is integrated with SOC/SIEM and incident playbooks are tested.

☐ Critical vulnerabilities and control exceptions have owners, due dates and approvals.

☐ Recovery, model rollback, key revocation and agent kill-switch procedures are tested.

☐ Vendor/model terms, data-use settings, location and retention are approved.

☐ Evidence is retained according to policy and accessible to authorized auditors.

13. Reference KPIs

Metric	Suggested baseline target	Notes
Inventory coverage	100% of production AI assets	Include models, agents, RAG stores and externally hosted endpoints.
Risk assessment coverage	100% before production	Reassess after material change.
Critical use cases independently tested	100% before release	Define criticality using the organization's risk policy.
RAG authorization test pass rate	100% of mandatory negative tests	Include cross-user and cross-tenant scenarios.
Agent tool permission review	100% at release and periodic review	Frequency based on risk; revoke unused permissions.
AI telemetry coverage	100% of production services emit defined audit events	Avoid collecting unnecessary sensitive prompt content.
Critical incident containment	Measured against approved incident SLA	Set the SLA based on service criticality and operating model.
High-risk finding remediation	Within approved risk-based SLA	Critical issues should block release or require formal exception.

14. Implementation Notes and Assumptions

- This is a vendor-neutral target design. Select products only after requirements, data residency, integration, scale, availability and procurement constraints are confirmed.
- A gateway or guardrail does not by itself prevent prompt injection, hallucination, or data leakage; use layered controls and test the complete workflow.
- AI outputs should not be treated as authoritative facts or executable instructions without validation appropriate to the use case.
- Applicable Indian law, sectoral regulations, government security directions, contractual obligations and data-protection requirements must be mapped by the organization’s legal and compliance teams.
- Certification claims must be based on an accredited/qualified assessment and actual scope; this document does not certify any platform or assert that controls are already deployed.

Appendix A — Implementation Deliverables

Deliverable	Owner	Acceptance evidence
AI asset and model inventory	AI platform owner	Approved registry export and owner confirmation
AI risk assessment and treatment plan	AI risk lead / use-case owner	Signed assessment and residual risk decisions
Security architecture and threat model	Security architect	Reviewed diagrams, trust boundaries, abuse cases
RAG authorization test suite	Data/AI engineering	Positive and negative access tests with results
Agent tool-permission matrix	Application owner / CISO	Approved tool, operation and approval mapping
Model and dependency provenance pack	MLOps / DevSecOps	Version records, SBOM, source and evaluation evidence
AI SOC detection pack	SOC lead	Use cases, alert rules, playbooks and exercise results
Independent assurance report	Internal audit / assessor	Findings, evidence references, remediation plan